

ELEC-H550: Embedded Systems Security

Jan Tobias Mühlberg

jan.tobias.muehlberg@ulb.be

Université libre de Bruxelles, Cybersecurity Research Center, Belgium

ULB, Brussels, 2026/2027

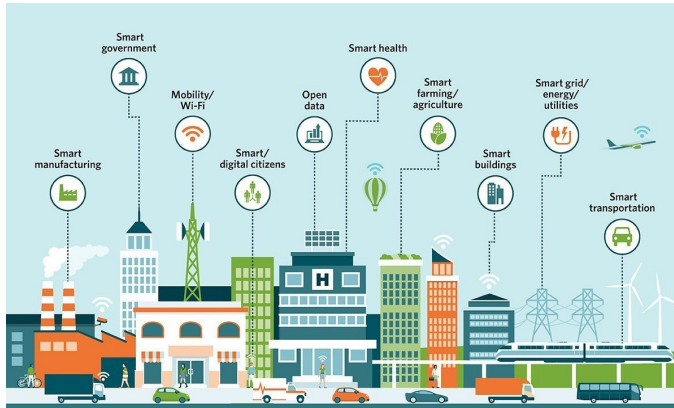
Session 1: Course Introduction

“We’re building self-driving cars and planning Mars missions – but we haven’t figured out how to make sure people’s vacuum cleaners don’t join botnets.”

— Someone at JSConfAU16

Source: <https://twitter.com/MelissaKaulfuss/status/804209991510937600?s=09>

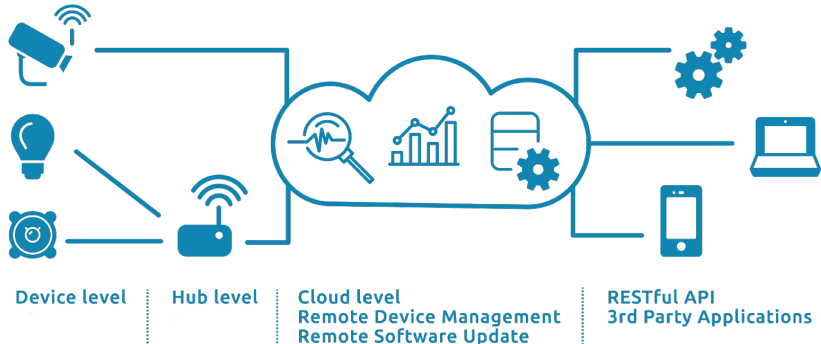
Security in Distributed Systems



Infrastructure needs to be developed with safety, security and privacy in mind! What is critical infrastructure? What is safety-critical? Where is personal data being processed? What's the impact of failure?

Image source: <https://internetofthingsagenda.techtarget.com/definition/smart-city>

Security in Distributed Systems



Understanding can be really difficult: What stake holders are involved? What are their objectives and abilities? What hardware and software is involved? Software quality? Data flows? Security requirements and guarantees?

Image source: <https://medium.com/connected-news/iot-foundation-what-is-an-iot-platform-c37c5e72d4a0>

Security in Distributed Systems

Facebook Is Breached by Hackers, Putting 50 Million Users' Data at Risk



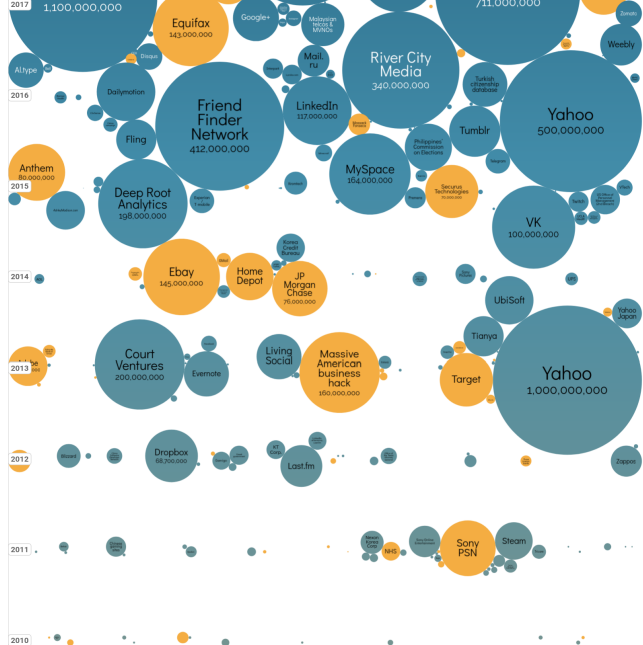
One of the challenges for Facebook's chief executive Mark Zuckerberg is convincing users that the company handles their data responsibly.

Source: <https://www.nytimes.com/2018/09/28/technology/facebook-hack-data-breach.html>

Jan Tobias Mühlberg

[illegible]

Security & Privacy at Scale





“The risks are about to get worse, because computers are being embedded into physical devices and will affect lives, not just our data.”

— Bruce Schneier, [Sch18]

LILLY HAY NEWMAN

MATT BURGESS

ANDY GREENBERG

SECURITY JUL 19, 2024 10:46 AM

How One Bad CrowdStrike Update Crashed the World's Computers

A defective CrowdStrike update sent computers around the globe into a reboot death spiral, taking down air travel, hospitals, banks, and more with it. Here's how that's possible.



PHOTO-ILLUSTRATION: WIRED STAFF; GETTY IMAGES

Source: <https://www.wired.com/story/crowdstrike-outage-update-windows/>

Sex

The looming deluge of connected dildos is a security nightmare

Just because the teledildonics patent has expired, sex tech companies shouldn't rush to bring connectivity to their products

Source: <https://www.wired.co.uk/article/teledildonics-hacking-sex-toys> (2017)

Smart dildos and vibrators keep getting hacked – but Tor could be the answer to safer connected sex

Connected sex toys are gathering huge amounts of data about our most intimate moments. Problem is, they're always getting hacked. Welcome to the emerging field of Onion Dildonics

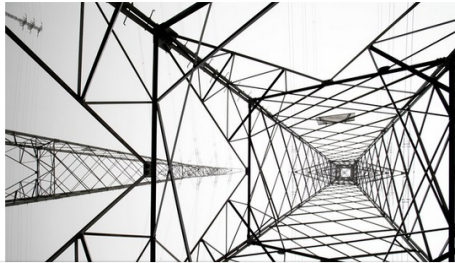
Source: <https://www.wired.co.uk/article/sex-toy-bluetooth-hacks-security-fix> (2018)

KIM ZETTER SECURITY 03.03.16 07:00 AM

SHARE



INSIDE THE CUNNING, UNPRECEDENTED HACK OF UKRAINE'S POWER GRID



Source: <https://www.wired.com/2016/03/inside-cunning-unprecedented-hack-ukraines-power-grid/>

Security in Distributed Systems

Support Guardian Europe

Fund independent journalism with €5 per month

Support us →

The Guardian

[News](#)[Opinion](#)[Sport](#)[Culture](#)[Lifestyle](#)[More ▾](#)

Environment ▶ Climate crisis Wildlife **Energy** Pollution

Nuclear Leaks

Energy industry

Anna Isaac and Alex
Lawson

Mon 4 Dec 2023 15:00 CET



Sellafield nuclear site hacked by groups linked to Russia and China

Exclusive: Malware may still be present and potential effects have been covered up by staff, investigation reveals

- 'Bottomless pit of hell, money and despair' at Europe's most toxic nuclear site
- Sellafield has leak that could pose risk to public



Some of Sellafield's most sensitive activities such as moving radioactive waste, monitoring for leaks and checking for fires may have been compromised. Composite: Guardian Design/Alamy

Most viewed



Earth on verge of five catastrophic climate tipping points, scientists warn



A moment that changed me: I was pregnant at 16 - and a midwife said I was good for nothing. It was a red rag to a bull



Trump tells Hannity he will be a dictator only on 'day one' if elected president



Texas school again suspends Black student for refusing to change his hair



Babies do not fall for illusion that fools older children, study finds

Source: <https://www.theguardian.com/business/2023/dec/04/sellafield-nuclear-site-hacked-groups-russia-china>

Unique Challenge in Embedded Systems!

“However, unlike consumer electronics, traditional power grid environments have a focus on long-term stability and plan for hardware life-spans of 10 years or more. As devices age, unknown vulnerabilities of hardware, operating system, software, and protocols emerge. Such vulnerabilities pose a serious threat to the infrastructure. While consumer electronics need not fulfil the same life-cycle requirements of industrial devices, their base technology is similar.”

– “Cyber attack models for smart grid environments”,
Eder-Neuhauser et al., [ENZFV17]

Safety vs. Security

Safety is protection against random incidents. Random incidents are unwanted and happen as a result of one or more coincidences.

Safety vs. Security

Safety is protection against random incidents. Random incidents are unwanted and happen as a result of one or more coincidences.

Security is protection against intended incidents. Intended incidents happen due to a result of deliberate and planned act.

Safety vs. Security

Safety is protection against random incidents. Random incidents are unwanted and happen as a result of one or more coincidences.

Security is protection against intended incidents. Intended incidents happen due to a result of deliberate and planned act.

- There is an *attacker*.
- Attackers has certain *goals*, which are conflicting with the goals of a system's stake-holders.
- Attackers have certain *abilities and resources*, which we specify in an *attacker model* to assess the attacker's "strength".
- Attackers are *intelligent and adaptive*. They may identify and exploit any unprotected entry point to compromise a system.

Safety vs. Security

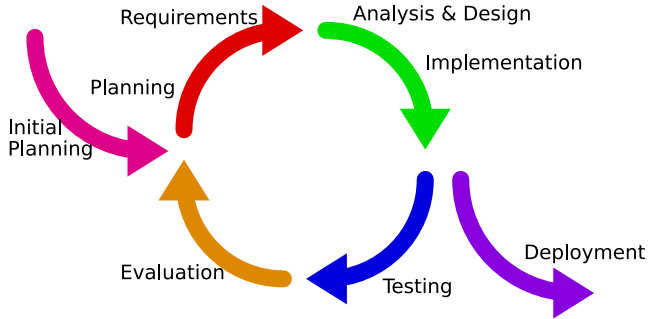
Safety is protection against random incidents. Random incidents are unwanted and happen as a result of one or more coincidences.

Security is protection against intended incidents. Intended incidents happen due to a result of deliberate and planned act.

- There is an *attacker*.
- Attackers has certain *goals*, which are conflicting with the goals of a system's stake-holders.
- Attackers have certain *abilities and resources*, which we specify in an *attacker model* to assess the attacker's "strength".
- Attackers are *intelligent and adaptive*. They may identify and exploit any unprotected entry point to compromise a system.

Safety + Security = Dependability, which is really hard to achieve.

Security in the Software Development Life-Cycle



Understand the system • Understand the security requirements •

Understand the attacker • Understand and embrace change!

This course is about asking the right questions at the right moment, learning about attacks and defences, and about arguing why and when something is **trustworthy**.

What can we trust?

Software?



Hardware?



Supply Chains?



People?



...

What can we trust?

Menu Search

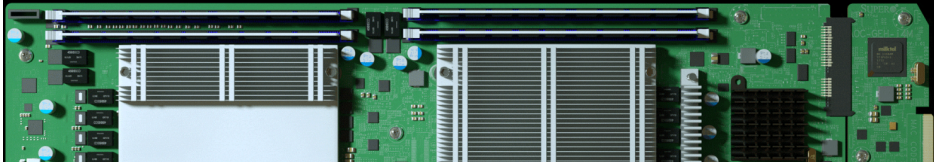
Bloomberg Businessweek

Sign In Subsc

October 2018, 11:00 CEST

The Big Hack: How China Used a Tiny Chip to Infiltrate U.S. Companies

The attack by Chinese spies reached almost 30 U.S. companies, including Amazon and Apple, by compromising America's technology supply chain, according to extensive interviews with government and corporate sources.



Source: <https://www.bloomberg.com/news/features/2018-10-04/the-big-hack-how-china-used-a-tiny-chip-to-infiltrate-america...>

What can we trust?

- **Reasoning about security is about setting boundaries**
 - Which parts are considered trusted, and which parts are not
 - How far do you want to go in defending your application
 - What kind of security is economically viable?
- **Building secure systems requires rigorous security arguments**
 - Having a good idea about what you are building
 - Determining which attackers are considered to be in scope
 - Analysing potential vulnerabilities, and introducing appropriate countermeasures

What can we trust?

- **Reasoning about security is about setting boundaries**
 - Which parts are considered trusted, and which parts are not
 - How far do you want to go in defending your application
 - What kind of security is economically viable?
- **Building secure systems requires rigorous security arguments**
 - Having a good idea about what you are building
 - Determining which attackers are considered to be in scope
 - Analysing potential vulnerabilities, and introducing appropriate countermeasures
- **A security argument is a rigorous argument that under a given adversary model, a countermeasure effectively counters a threat, or a security mechanism achieves a security goal.**

Common Attack Scenarios in Embedded Systems [PMB15]

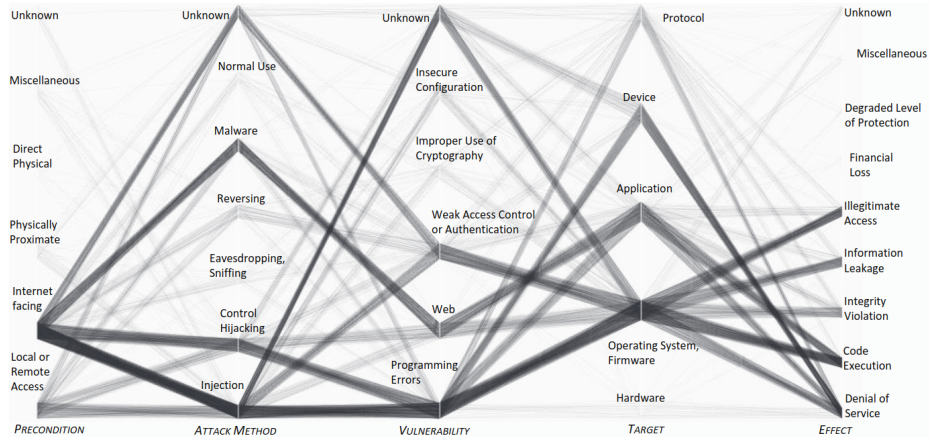


Fig. 1. Common Attack Scenarios

Source: Papp et al., "Embedded systems security: Threats, vulnerabilities, and attack taxonomy", 2015.

<https://doi.org/10.1109/PST.2015.7232966>

The Plan for ELEC-H550

- 1 The information security landscape and the the role of safety, security, and data protection in embedded systems
- 2 Low-level vulnerabilities and defences in software and hardware
- 3 Vulnerabilities and defences in light-weight embedded systems
- 4 Automated detection, exploitation, and prevention of vulnerabilities in software
- 5 System security and secure hardware
- 6 Sustainability aspects in security and privacy engineering
- 7 Security assessment techniques
- 8 **Exercises:** Threat modeling, software fuzzing, exploitation techniques
- 9 **Project:** Your own research

References I

-  T. Avgerinos, S. K. Cha, A. Rebert, E. J. Schwartz, M. Woo, and D. Brumley.
Automatic exploit generation.
Commun. ACM, 57(2):74–84, 2014.
-  M. Busi, J. Noorman, J. Van Bulck, L. Galletta, P. Degano, J. T. Mühlberg, and F. Piessens.
Provably secure isolation for interruptible enclaved execution on small microprocessors.
In *Computer Security Foundations Symposium (CSF)*. IEEE, 2020.
-  D. Brumley, P. Poosankam, D. Song, and J. Zheng.
Automatic patch-based exploit generation is possible: Techniques and implications.
In *2008 IEEE Symposium on Security and Privacy (S&P 2008)*, pp. 143–157, 2008.
-  C. Cadar, D. Dunbar, D. R. Engler, et al.
Klee: Unassisted and automatic generation of high-coverage tests for complex systems programs.
In *OSDI*, vol. 8, pp. 209–224, 2008.
-  C. Canella, J. Van Bulck, M. Schwarz, M. Lipp, B. Von Berg, P. Ortner, F. Piessens, D. Evtushkin, and D. Gruss.
A systematic evaluation of transient execution attacks and defenses.
In *28th USENIX Security Symposium (USENIX Security 19)*, pp. 249–266, 2019.
-  H. Depuydt, M. Gülmez, T. Nyman, and J. T. Mühlberg.
Do we still need canaries in the coal mine? measuring shadow stack effectiveness in countering stack smashing.
In *2025 International Conference on Availability, Reliability and Security (ARES)*, vol. 15993 of *LNCS*, pp. 193–205. Springer, 2025.
-  Y. Dimova, K. Mrunmayee, S. Kalantari, K. Wuyts, W. Joosen, and J. T. Mühlberg.
From privacy policies to privacy threats: A case study in policy-based threat modeling.
In *Proceedings of the 22nd Workshop on Privacy in the Electronic Society (WPES '23)*, New York, NY, USA, 2023. ACM.

References II



D. Dolev and A. C. Yao.

On the security of public key protocols.

In *Proceedings of the 22Nd Annual Symposium on Foundations of Computer Science, SFCS '81*, pp. 350–357, Washington, DC, USA, 1981. IEEE Computer Society.



P. Eder-Neuhauser, T. Zseby, J. Fabini, and G. Vormayr.

Cyber attack models for smart grid environments.

Sustainable Energy, Grids and Networks, 12:10–29, December 2017.



Ú. Erlingsson, Y. Younan, and F. Piessens.

Low-Level Software Security by Example, pp. 633–658.

Springer Berlin Heidelberg, Berlin, Heidelberg, 2010.



P. Godefroid, M. Y. Levin, and D. Molnar.

Automated whitebox fuzz testing.

In *NDSS '08*. Internet Society (ISOC), 2008.



S. K. Huang, M. H. Huang, P. Y. Huang, H. L. Lu, and C. W. Lai.

Software crash analysis for automatic exploit generation on binary programs.

IEEE Transactions on Reliability, 63(1):270–289, 2014.



C. He, M. Sundararajan, A. Datta, A. Derek, and J. C. Mitchell.

A modular correctness proof of ieee 802.11i and tls.

In *Proceedings of the 12th ACM Conference on Computer and Communications Security, CCS '05*, pp. 2–15, New York, NY, USA, 2005. ACM.

References III

- 
- B. Jacobs, J. Smans, and F. Piessens.
VeriFast: Imperative programs as proofs.
In VSTTE 2010 workshop proceedings, pp. 63–72, 2010.
- 
- P. Kocher, D. Genkin, D. Gruss, W. Haas, M. Hamburg, M. Lipp, S. Mangard, T. Prescher, M. Schwarz, and Y. Yarom.
Spectre attacks: Exploiting speculative execution.
ArXiv e-prints, January 2018.
- 
- P. Maene, J. Götzfried, R. de Clercq, T. Müller, F. Freiling, and I. Verbauwhede.
Hardware-based trusted computing architectures for isolation and attestation.
IEEE Transactions on Computers, PP(99):1–1, 2017.
- 
- J. T. Mühlberg and G. Lüttgen.
Symbolic object code analysis.
In SPIN '10, vol. 6349 of *LNCS*, pp. 4–21, Heidelberg, 2010. Springer.
- 
- C. Miller and C. Valasek.
Remote exploitation of an unaltered passenger vehicle.
Black Hat USA, 2015.
- 
- J. Noorman, J. T. Mühlberg, and F. Piessens.
Authentic execution of distributed event-driven applications with a small TCB.
In STM '17, vol. 10547 of *LNCS*, pp. 55–71, Heidelberg, 2017. Springer.
- 
- J. Noorman, J. Van Bulck, J. T. Mühlberg, F. Piessens, P. Maene, B. Preneel, I. Verbauwhede, J. Götzfried, T. Müller, and F. Freiling.
Sancus 2.0: A low-cost security architecture for IoT devices.
ACM Transactions on Privacy and Security (TOPS), 20:7:1–7:33, 2017.

References IV



D. Papp, Z. Ma, and L. Buttyan.

Embedded systems security: Threats, vulnerabilities, and attack taxonomy.
In 2015 13th Annual Conference on Privacy, Security and Trust (PST), pp. 145–152. IEEE, 2015.



P. Philippaerts, J. T. Mühlberg, W. Penninckx, J. Smans, B. Jacobs, and F. Piessens.

Software verification with VeriFast: Industrial case studies.
Science of Computer Programming (SCP), 82:77–97, 2014.



F. Piessens and I. Verbauwheide.

Software security: Vulnerabilities and countermeasures for two attacker models.
In 2016 Design, Automation & Test in Europe Conference & Exhibition (DATE), pp. 990–999, 2016.



F. Piessens and P. C. van Oorschot.

Side-channel attacks: A short tour.
IEEE Security & Privacy, 22(2):75–80, 2024.



B. Schneier.

Internet hacking is about to get much worse.
The New York Times, 10 2018.



A. Shostack.

Threat modeling: Designing for security.
John Wiley & Sons, 2014.



M. Schneider, R. J. Masti, S. Shinde, S. Capkun, and R. Perez.

Sok: Hardware-supported trusted execution environments.
arXiv preprint arXiv:2205.12742, 2022.

References V



G. Scopelliti, S. Pouyanrad, J. Noorman, F. Alder, C. Baumann, F. Piessens, and J. T. Mühlberg.
End-to-End Security for Distributed Event-Driven Enclave Applications on Heterogeneous TEEs.
ACM Transactions on Privacy and Security, 2023.



J. Szefer.
Principles of Secure Processor Architecture Design, pp. 113–124.
Springer International Publishing, Cham, 2019.



N. Tillmann and J. de Halleux.
Pex – White Box Test Generation for .NET, pp. 134–153.
Springer Berlin Heidelberg, Berlin, Heidelberg, 2008.



J. Van Bulck, J. T. Mühlberg, and F. Piessens.
VulCAN: Efficient component authentication and software isolation for automotive control networks.
In *ACSAC '17*, pp. 225–237, New York, NY, USA, 2017. ACM.



J. Van Bulck, F. Piessens, and R. Strackx.
Nemesis: Studying microarchitectural timing leaks in rudimentary cpu interrupt logic.
In *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security*, pp. 178–195. ACM, 2018.



M. Vanhoef and F. Piessens.
Key reinstallation attacks: Forcing nonce reuse in wpa2.
In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, CCS '17, pp. 1313–1328, New York, NY, USA, 2017. Association for Computing Machinery.

References VI



J. Wilson, M. Asplund, N. Johansson, and F. Boeira.

Provably secure communication protocols for remote attestation.

In *Proceedings of the 19th International Conference on Availability, Reliability and Security, ARES '24*, New York, NY, USA, 2024. Association for Computing Machinery.



H. Winderix, J. T. Mühlberg, and F. Piessens.

Compiler-assisted hardening of embedded software against interrupt latency side-channel attacks.

In *EuroS&P '21*, pp. 667 – 682, Washington, DC, USA, 2021. IEEE.



K. Wuyts, L. Sion, and W. Joosen.

Linddun go: A lightweight approach to privacy threat modeling.

In *2020 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pp. 302–309, USA, 2020. IEEE.



M. Zalewski.

American Fuzzy Lop: A security-oriented fuzzer, 2010.

<http://lcamtuf.coredump.cx/afl/>.